

Cyber Threat Intelligence

Executive Briefing

Report Date: June 30, 2026

Generated: 2026-06-30 13:43 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	11	8	1	20

2. Executive Summary

As of June 30, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as 0 Critical, 11 High, 8 Medium, and 1 Low. The current organizational risk posture remains elevated, requiring immediate remediation to address vulnerabilities that present a high impact to confidentiality, integrity, and availability within our production environments. The primary security priority is CVE-2026-55698, identified as Lockfile Resolution Short-Circuiting in pnpm, due to its potential for facilitating supply chain compromise via attacker-controlled lockfile mechanisms. Given the nature of these findings, the recommended response posture is an immediate shift to emergency patch management protocols for all identified High-severity items. We advise leadership to authorize the prioritization of these technical remediation efforts over non-essential service deployments to maintain organizational resilience.

3. Critical Action List

- Execute immediate patch deployment for CVE-2026-55698 within 24 hours to mitigate lockfile resolution risks.
- Implement file system access controls and patch CVE-2026-49340 within 48 hours to prevent unauthorized arbitrary file writes.
- Reconfigure OpenAM JWKS caching mechanisms to resolve CVE-2026-47426 within 72 hours.
- Restrict Groovy script execution capabilities and patch CVE-2026-47424 within 72 hours to eliminate RCE vectors.
- Disable native install engine functionality in pnpm and apply necessary vendor updates for CVE-2026-55697 within 72 hours.
- Identify and remediate remaining six High-severity vulnerabilities within 5 business days to maintain compliance with internal security policy.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-55698	Lockfile Resolution Short-Circuit...	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in Gonic Pla...	8.1	High	83/100	CWE-22
CVE-2026-47426	OAuth Client Impersonation in Ope...	8.8	High	79/100	CWE-287
CVE-2026-47424	RCE via Groovy Sandbox Escape	8.8	High	79/100	CWE-693
CVE-2026-55697	Native Install Engine Hijacking i...	7.5	High	78/100	CWE-78
CVE-2026-55487	Lifecycle Execution via Manifest ...	7.5	High	78/100	CWE-346
CVE-2026-55700	Path Traversal in pnpm Downloader	7.1	High	74/100	CWE-22
CVE-2026-49338	IDOR in Subsonic API Playlist Man...	7.1	High	74/100	CWE-285
CVE-2026-49339	Playlist Path Traversal in Gonic	7.1	High	74/100	CWE-22
CVE-2026-48717	OAuth Authorization Bypass in Ope...	8.1	High	73/100	CWE-285
CVE-2026-53523	Host Header Injection in Nezha OA...	6.8	Medium	71/100	CWE-601
CVE-2026-55180	Environment Secret Disclosure in ...	6.5	Medium	69/100	CWE-200
CVE-2026-53522	WebSocket Resource Exhaustion in ...	6.5	Medium	69/100	CWE-770
CVE-2026-44840	DQL Injection in Dgraph GraphQL	7.5	High	68/100	CWE-943
CVE-2026-53465	Heap Buffer Over-Write in ImageMa...	6.2	Medium	66/100	CWE-122
CVE-2026-55699	PNPM_HOME Deletion via Reserved B...	6.5	Medium	59/100	CWE-22
CVE-2026-54243	CSV Formula Injection in Statamic	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Wand	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF in Statamic Glide via Rebind...	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Unauthorized Live Preview Submiss...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Lockfile Resolution Short-Circuiting in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The pnpm project environment lockfile mechanism allows for resolution short-circuiting, where an attacker-controlled lockfile can force the execution of arbitrary bytes. This poses a significant supply chain risk.

Proof of Concept (PoC):

An attacker provides a project containing a malicious lockfile. When a user runs pnpm install, the tool is tricked into

resolving and executing bytes designated by the attacker rather than those from the legitimate registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in Gonic Playlists

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1105, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Gonic contains an arbitrary file write vulnerability within the playlist creation process. Any authenticated user can force the application to write M3U content to attacker-specified paths on the host system.

Proof of Concept (PoC):

An attacker creates a playlist using a name containing directory traversal characters. When saved, Gonic writes the playlist content into an arbitrary location on the server, potentially overwriting configuration or system files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-47426

Finding: OAuth Client Impersonation in OpenAM

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-287

MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenAM is vulnerable to client impersonation caused by issues in the JWKS resolver cache. This allows an attacker to manipulate cached key sets to forge tokens, facilitating the impersonation of legitimate clients or users.

Proof of Concept (PoC):

The attacker performs a cache poisoning attack on the JWKS endpoint configuration. Once the cache is corrupted with a malicious public key, the attacker signs a fake JWT, which the OpenAM server accepts as valid due to the poisoned cache entry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47426>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47426>

CVE-2026-47424

Finding: RCE via Groovy Sandbox Escape

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-693

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenAM features an authenticated Remote Code Execution vulnerability via a Groovy sandbox escape. A malicious user with sufficient privileges can bypass security restrictions to execute arbitrary code on the underlying host.

Proof of Concept (PoC):

An authenticated user provides a specially crafted script targeting the Groovy engine. The script breaks out of the predefined sandbox environment, allowing the attacker to execute shell commands with the privileges of the application process.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47424>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47424>

CVE-2026-55697

Finding: Native Install Engine Hijacking in pnpm

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm configuration allows for repository-controlled dependencies to specify native install engines. This enables an attacker to define arbitrary native code execution during the installation phase.

Proof of Concept (PoC):

An attacker publishes a package with a configDependency that forces pnpm to use a malicious native engine. When a developer installs the package, the engine executes arbitrary native commands on the victim's machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Lifecycle Execution via Manifest Spoofing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm manifests can be spoofed to satisfy allowBuilds configurations, resulting in the execution of arbitrary lifecycle scripts. This allows attackers to perform unauthorized actions during package installation.

Proof of Concept (PoC):

The attacker creates a malicious package that presents itself as a trusted identity. pnpm evaluates the identity as valid, ignores standard build security protocols, and executes the payload contained in the package's lifecycle scripts.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

Finding: Path Traversal in pnpm Downloader

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

pnpm's stage download component is vulnerable to directory traversal via malicious manifest metadata. This allows an attacker to write files outside of the intended target directory, potentially leading to arbitrary file overwrite.

Proof of Concept (PoC):

An attacker creates a malicious package with a manifest containing traversal sequences in the version or name field. When a victim installs this package, the pnpm tool follows the traversal, writing files to unintended locations on the system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: IDOR in Subsonic API Playlist Management

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

Subsonic API is vulnerable to Insecure Direct Object Reference (IDOR) during playlist management. Authenticated users can read or delete playlists belonging to any other user by manipulating the playlist ID.

Proof of Concept (PoC):

An authenticated user sends an API request to delete or read a playlist, substituting the ID with one belonging to another user. The application fails to verify ownership, allowing the unauthorized action to proceed.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Playlist Path Traversal in Gonic

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Gonic is vulnerable to path traversal within the playlist ID parameter. This bypasses ownership checks and allows authenticated users to manipulate files or delete playlists across the application.

Proof of Concept (PoC):

The user submits a request with a playlist ID formatted as a traversal string (e.g., ../../other_user/playlist). The application resolves the path incorrectly, granting access to resources outside the intended scope.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-48717

Finding: OAuth Authorization Bypass in OpenAM

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-285

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM exhibits an authorization bypass flaw related to PKCE challenge validation. An attacker can leverage this failure to circumvent OAuth authentication flow requirements, enabling unauthorized access to protected resources.

Proof of Concept (PoC):

An attacker initiates an OAuth flow and deliberately misconfigures or ignores the PKCE challenge exchange. If the server incorrectly verifies the flow, the attacker receives a valid authorization token for a session they did not properly authenticate.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48717>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48717>

CVE-2026-53523

Finding: Host Header Injection in Nezha OAuth

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601

MITRE ATT&CK: T1566, T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring is vulnerable to Host Header Injection during OAuth2 redirection. Attackers can manipulate the redirect URL, potentially leading to phishing or account takeover via token interception.

Proof of Concept (PoC):

An attacker sends a request with a modified Host header targeting the OAuth redirect endpoint. The server uses this header to construct the redirect URL, causing the user to be redirected to an attacker-controlled site with auth tokens.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55180

Finding: Environment Secret Disclosure in pnpm

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-200

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

pnpm allows repository configuration to expand environment variables into registry requests. This leads to the inadvertent disclosure of sensitive local secrets to remote servers.

Proof of Concept (PoC):

A user clones a malicious repository containing a pnpm configuration that forces variable expansion. When the user executes pnpm, local environment secrets are injected into outgoing requests, sending the data to the attacker's registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-53522**Finding: WebSocket Resource Exhaustion in Nezha**

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring allows unbounded WebSocket streams, leading to resource exhaustion. An attacker can open multiple connections to consume memory and CPU, causing a denial of service.

Proof of Concept (PoC):

An attacker script opens a massive number of concurrent WebSocket connections to the target API. The absence of stream limits leads to memory exhaustion, eventually causing the service to crash or become unresponsive.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-44840**Finding: DQL Injection in Dgraph GraphQL**

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-943

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dgraph is susceptible to a DQL Injection vulnerability within the checkUserPassword GraphQL query. An attacker can manipulate input parameters to execute unauthorized DQL queries, potentially leading to unauthorized data disclosure.

Proof of Concept (PoC):

An attacker sends a crafted GraphQL query to the checkUserPassword endpoint containing injected DQL syntax. The Dgraph engine interprets the injected commands, allowing the attacker to retrieve sensitive user information from the backend database.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44840>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44840>

CVE-2026-53465

Finding: Heap Buffer Over-Write in ImageMagick

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122

MITRE ATT&CK: T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	High

Description:

ImageMagick's SF3 encoder contains a heap buffer overflow vulnerability when processing multi-frame images. This can lead to arbitrary code execution or process crashes.

Proof of Concept (PoC):

An attacker uploads a specially crafted multi-frame image file to a server utilizing ImageMagick for processing. The encoder, when triggered, writes beyond the heap buffer bounds, corrupting memory and potentially executing attacker code.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-55699

Finding: PNPM_HOME Deletion via Reserved Bin

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-22

MITRE ATT&CK: T1485

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Local
---------------	-------

Attack Complexity	Low
-------------------	-----

Privileges Required	High
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

pnpm incorrectly handles reserved binary names during global removal, potentially triggering the deletion of the entire PNPM_HOME directory. This results in significant loss of availability for the development environment.

Proof of Concept (PoC):

A user with high privileges removes a package with a specific reserved bin name using the global remove command. The pnpm logic fails to isolate the path, resulting in the recursive deletion of the directory containing the manager's home.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-54243

Finding: CSV Formula Injection in Statamic

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1566, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	Low

Description:

Statamic is vulnerable to CSV formula injection in exported form submissions. Attackers can embed malicious Excel formulas in form fields, which execute when the export is opened by an administrator.

Proof of Concept (PoC):

An attacker submits a form entry starting with an Excel formula operator (e.g., =cmd|' /C calc!A0). When an admin exports the form data to CSV and opens it in Excel, the malicious command is executed locally.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-53464

Finding: Memory Leak in ImageMagick Wand

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None

Attack Complexity	Low
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	None
Availability Impact	Low

Description:

A memory leak exists in the ImageMagick wand option parser when processing invalid arguments. Repeated triggering of this condition can lead to exhaustion of system memory, causing denial of service.

Proof of Concept (PoC):

An attacker sends a flood of requests with intentionally malformed arguments to the ImageMagick parser. Each request causes a small memory leak, which, over time, depletes available system resources and halts the service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>

CVE-2026-54242

Finding: SSRF in Statamic Glide via Rebinding

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide component is vulnerable to Server-Side Request Forgery via DNS rebinding. This allows an attacker to bypass firewalls and access internal resources that are otherwise restricted.

Proof of Concept (PoC):

An attacker registers a domain and uses DNS rebinding to point it to internal IP addresses. By providing this URL to the Glide image processing engine, the attacker tricks the server into making requests to internal network services.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>

CVE-2026-54244

Finding: Unauthorized Live Preview Submission

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS features an authorization defect allowing users with view-only permissions to submit content to the Live Preview environment. This could allow unauthorized content modification in preview contexts.

Proof of Concept (PoC):

A low-privileged user authenticates and accesses the Live Preview feature, which should be reserved for editors. The user submits data that gets processed, confirming the lack of granular permission checks.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>